TP 1.3—INTRODUCTION A LA THREAT INTELLIGENCE ET RCHERCHE DE VULNERABILTES

1. Introduction

Définition de la Threat Intelligence

La **Threat Intelligence** (ou renseignement sur les menaces) est le processus de collecte, d'analyse et de diffusion d'informations concernant les cybermenaces existantes ou émergentes. Elle s'appuie sur des données provenant de diverses sources (publiques, privées, techniques) pour comprendre les intentions et les méthodes des attaquants.

Rôle dans la cybersécurité

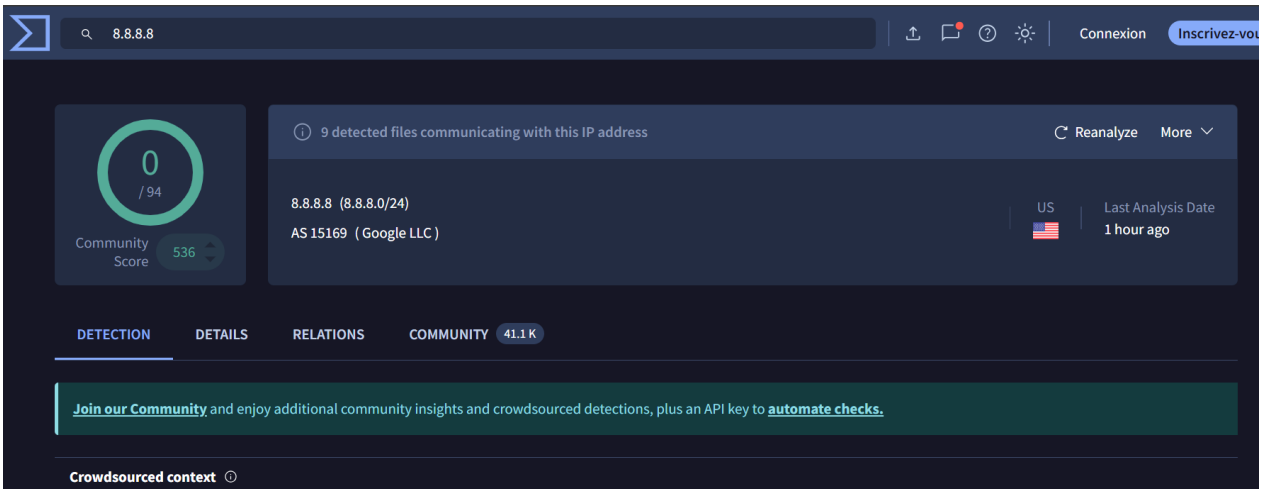
Elle joue un rôle crucial en permettant aux défenseurs de passer d'une posture réactive à une posture **proactive**. Elle aide à :

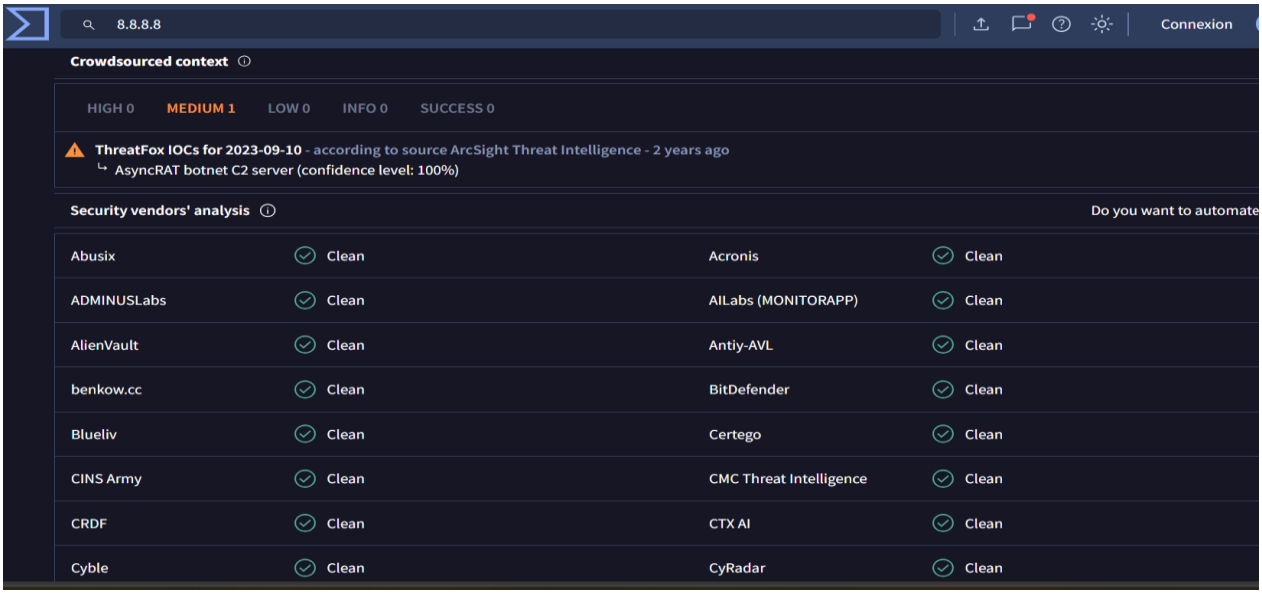
- Identifier les nouveaux vecteurs d'attaque.
- Prioriser les correctifs en fonction des vulnérabilités réellement exploitées.
- Accélérer la détection des incidents au sein d'un SOC (Security Operations Center).

2. Analyse de l'adresse IP

Objectif : Évaluer la réputation d'une IP externe suspecte à l'aide de sources publiques (VirusTotal).

- **Capture du résultat sur VirusTotal :**





- **Interprétation du score :** Le score indique le nombre de moteurs de sécurité ayant détecté l'IP comme malveillante.
- **Conclusion sur la dangerosité :** Déterminer si l'IP doit être bloquée ou si elle est légitime (DNS public).

3. Analyse des services (AVEC CAPTURES)

Objectif : Relier les résultats d'un scan réseau aux vulnérabilités connues.

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 09:48 +0200
Nmap scan report for 192.168.56.5
Host is up (0.0012s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol
2.0)
MAC Address: 08:00:27:FA:5A:43 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.97 seconds
```

Rappel des services identifiés lors du scan (OpenSSH).

Identification d'un service

Ciblage d'un service spécifique pour l'analyse (OpenSSH 8.2p1).

Capture searchsploit (searchsploit OpenSSH)

```
┌──(awouna㉿awouna)-[~]
└─$ searchsploit OpenSSH
---------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------------
Debian OpenSSH - (Authenticated) Remote SE | linux/remote/6094.txt
Dropbear / OpenSSH Server - 'MAX_UNAUTH_CL | multiple/dos/1572.pl
FreeBSD OpenSSH 3.5p1 - Remote Command Exe | freebsd/remote/17462.txt
glibc-2.2 / openssh-2.3.0p1 / glibc 2.1.9x | linux/local/258.sh
Novell Netware 6.5 - OpenSSH Remote Stack  | novell/dos/14866.txt
OpenSSH 1.2 - '.scp' File Create/Overwrite | linux/remote/20253.sh
OpenSSH 2.3 < 7.7 - Username Enumeration   | linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration ( | linux/remote/45210.py
OpenSSH 2.x/3.0.1/3.0.2 - Channel Code Off | unix/remote/21314.txt
OpenSSH 2.x/3.x - Kerberos 4 TGT/AFS Token | linux/remote/21402.txt
OpenSSH 3.x - Challenge-Response Buffer Ov | unix/remote/21578.txt
OpenSSH 3.x - Challenge-Response Buffer Ov | unix/remote/21579.txt
OpenSSH 4.3 p1 - Duplicated Block Remote D | multiple/dos/2444.sh
OpenSSH 6.8 < 6.9 - 'PTY' Local Privilege  | linux/local/41173.c
OpenSSH 7.2 - Denial of Service            | linux/dos/40888.py
OpenSSH 7.2p1 - (Authenticated) xauth Comm | multiple/remote/39569.py
OpenSSH 7.2p2 - Username Enumeration       | linux/remote/40136.py
OpenSSH < 6.6 SFTP (x64) - Command Executi | linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution     | linux/remote/45001.py
```

```
OpenSSH 7.2p2 - Username Enumeration          | linux/remote/40136.py
OpenSSH < 6.6 SFTP (x64) - Command Executi | linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution        | linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Di | linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary L | linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)          | linux/remote/45939.py
OpenSSH SCP Client - Write Arbitrary Files | multiple/remote/46516.py
OpenSSH server (sshd) 9.8p1 - Race Conditi | linux/remote/52269.c
OpenSSH/PAM 3.6.1p1 - 'gossh.sh' Remote Us | linux/remote/26.sh
OpenSSH/PAM 3.6.1p1 - Remote Users Discove | linux/remote/25.c
OpenSSHd 7.2p2 - Username Enumeration         | linux/remote/40113.txt
Portable OpenSSH 3.6.1p-PAM/4.1-SuSE - Tim | multiple/remote/3303.sh
---------------------------------------------- ------------------------------------
Shellcodes: No Results
```

Explication des vulnérabilités

D'après les résultats de searchsploit, plusieurs vulnérabilités affectent OpenSSH selon les versions :

● Énumération d'utilisateurs (Username Enumeration) : Permet à un attaquant de dresser une liste d'utilisateurs valides en observant les réponses du serveur (ex: versions < 7.7).

● Exécution de code à distance (Remote Command Execution) : Faille critique permettant de prendre le contrôle du serveur sans compte utilisateur (ex: version 3.5p1).

● Élévation de privilèges (Local Privilege Escalation) : Permet à un utilisateur avec un accès limité de devenir "Root" (ex: versions 6.8 < 6.9).

● Déni de Service (DoS) : Envoi de paquets spécifiques pour faire planter le service OpenSSH (ex: version 7.2).

4. Étude d'une CVE (Analyse Technique)

Laboratoire des technologies de l'information

BASE DE DONNÉES NATIONALE DES VULNÉRABILITÉS

NIST NATIONAL VULNERABILITY DATABASE NVD

VULNÉRABILITÉS

CVE-2018-15473 Détails

MODIFIÉ APRÈS ENRICHISSEMENT

Ce dossier CVE a été mis à jour après la fin des efforts d'enrichissement du NVD. Les données d'enrichissement fournies par le NVD peuvent nécessiter des modifications en raison de ces changements.

Description

OpenSSH jusqu'à la version 7.7 est sujette à une vulnérabilité d'énumération utilisateur en raison du fait qu'il ne retarde pas le renflouement d'un utilisateur authentifiant invalide avant que le paquet contenant la requête n'ait été

PETITE INFO

Entrée du dictionnaire CVE : CVE-2018-15473
NVD Date de publication : 17/08/2018
NVD Dernière modification : 17/12/2025
Source :

Métriques

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

Les efforts d'enrichissement NVD font référence aux informations publiques disponibles à leurs associés chaînes vectorielles. Les informations du CVSS fournies par d'autres sources sont également présentes affiché.

Sévérité et chaînes vectorielles CVSS 3.x :

NIST : NVD	**Base Note :** 5.3 MOYEN	**Vecteur :** CVSS : 3.1/AV :N/AC :L/PR :N/UI :N/S :U/C :L/I :N/A :N
ADP : CISA-ADP	**Base Note :** 5.9 MOYEN	**Vecteur :** CVSS : 3.1/AV :N/AC :H/PR :N/UI :N/S :U/C :H/I :N/A :N

Commutateur de configurations logicielles connues affectées

vers CPE 2.2

Configuration 1 (masquer)

CPE :2.3 :A :OpenBSD :OpenSSH :*:*:*:*:*:*:*:* Afficher des CPE(s) correspondants	**Jusqu'à (y compris) 7,7**

Configuration 2 (hide)

CPE :2.3 :O :debian :debian_linux :8.0 :*:*:*:*:*:*:*:*
Afficher des CPE(s) correspondants

CPE :2.3 :O :debian :debian_linux :9.0 :*:*:*:*:*:*:*:*
Afficher des CPE(s) correspondants

Configuration 3 (hide)

CPE :2.3 :O :RedHat :enterprise_linux_desktop :6.0 :*:*:*:*:*:*:*:*
Afficher des CPE(s) correspondants

CPE :2.3 :O :RedHat :enterprise_linux_desktop :7.0 :*:*:*:*:*:*:*:*

Description

La CVE-2018-15473 est une vulnérabilité d'énumération d'utilisateurs qui affecte OpenSSH jusqu'à la version 7.7.
Elle repose sur la manière dont le serveur SSH traite les requêtes d'authentification malformées. Le serveur répond différemment (ou met un temps différent à répondre) selon que l'utilisateur existe ou non sur le système.

Impact

Confidentialité : Cette faille permet à un attaquant de découvrir la liste des comptes valides sur un serveur cible (ex: admin, root, service_web).

Vecteur d'attaque : Une fois que l'attaquant connaît les noms d'utilisateurs réels, il peut lancer des attaques par brute-force ou par dictionnaire beaucoup plus ciblées et efficaces pour deviner les mots de passe.

Niveau de gravité

Score CVSS v3 : 5.3 (Moyen).

Bien que le score semble modéré, c'est une étape cruciale de la phase de reconnaissance (Footprinting) qui précède souvent une intrusion majeure.

Exploitation possible

L'exploitation se fait généralement via un script Python (comme ceux listés dans ton searchsploit). Le script envoie des paquets d'authentification spécifiques et analyse la réponse du serveur.

* Si le serveur rejette la requête immédiatement : l'utilisateur n'existe probablement pas.
* Si le serveur traite la requête différemment : l'utilisateur est confirmé.

5. Utilisation avancée de searchsploit

Présentation de 3 options avancées :

searchsploit -x:

- *Rôle :* Examine le contenu d'un exploit.
- *Exemple :* searchsploit -x php/webapps/4567.py
- *Utilité :* Comprendre le code avant exécution.

2. **searchsploit -m ** :
   - *Rôle :* Copie un exploit dans le répertoire de travail actuel. ● *Exemple :* searchsploit -m 12345
   - *Utilité :* Facilite la modification de l'exploit.
3. **searchsploit -u** :
   - *Rôle :* Met à jour la base de données locale. ● *Exemple :* searchsploit -u
   - *Utilité :* Obtenir les derniers exploits publiés.

6. Analyse globale de sécurité

- **Quels sont les risques identifiés ?** Risques d'intrusion, de déni de service ou d'exfiltration de données via des services obsolètes.
- **Quel service est le plus dangereux ?** Souvent celui présentant des vulnérabilités de type RCE (Remote Code Execution).
- **Quelles actions recommanderiez-vous ?** Mise à jour (patching), durcissement des configurations et surveillance accrue des logs.

7. Lien avec l'entreprise

- **Comment un SOC utilise la Threat Intelligence :** Un SOC utilise ces données pour anticiper les attaques en surveillant les IoC (Indicateurs de Compromission) et en priorisant les alertes.
- **Comment anticiper une attaque :** En pratiquant une veille constante (OSINT) et en effectuant des scans de vulnérabilités réguliers.

8. Conclusion

- **Ce que j'ai appris :** Compréhension de la chaîne d'analyse, de l'identification d'une IP à la recherche d'exploits spécifiques.
- **Limites de l'analyse :** Les bases de données ne sont pas toujours exhaustives pour les vulnérabilités "Zero-day".